

Relatório de Conformidade – LGPD e Segurança de Dados

Projeto: SUSi - Regulação e Absenteísmo no SUS **Data:** 12/06/2026 **Equipe:** Jess Forster, Lucas Almeida

1. Descrição do Cenário

O projeto SUSi analisa dados oriundos do Sistema Único de Saúde (SUS), integrando bases como SISREG, CNES e DATASUS para identificar os determinantes do absenteísmo (no-show) em consultas e exames especializados.

Os dados processados incluem registros de agendamentos, especialidades médicas, localização geográfica (município) e status de comparecimento. Embora a base principal utilize dados abertos ou previamente desidentificados para fins estatísticos, o ecossistema de saúde lida inerentemente com dados pessoais e dados pessoais sensíveis (informações de saúde), conforme definido pela Lei Geral de Proteção de Dados (LGPD).

A finalidade declarada para o uso destes dados é estritamente analítica e preditiva: desenvolver um modelo capaz de prever o risco de absenteísmo e otimizar a fila de regulação, sem finalidade comercial ou de identificação individual dos pacientes.

2. Riscos Identificados

Apesar da natureza analítica do projeto, foram identificados os seguintes riscos no ciclo de vida dos dados:

- **Risco de Reidentificação:** O cruzamento de múltiplas variáveis demográficas (como município, idade, especialidade rara e data de agendamento) pode permitir a reidentificação indireta de pacientes, configurando uma violação de privacidade.
- **Exposição de Dados Sensíveis:** O armazenamento inadequado ou a transmissão não criptografada da base de dados pode expor o histórico médico e de agendamentos.
- **Controle de Acesso Insuficiente:** A ausência de segmentação de perfis pode permitir que usuários sem necessidade técnica acessem a granularidade máxima dos dados.

3. Medidas de Segurança Aplicadas

Para mitigar os riscos identificados e garantir a proteção dos dados, as seguintes medidas foram implementadas na arquitetura do projeto:

- **Técnicas de Anonimização:** Remoção sumária de identificadores diretos (nome, CPF, Cartão Nacional de Saúde) no pipeline de ETL (Extração, Transformação e Carga).
- **Pseudonimização e Agregação:** Variáveis geográficas muito granulares foram agregadas por município ou região de saúde. Datas exatas de nascimento foram convertidas em faixas etárias.
- **Políticas de Controle de Acesso:** O acesso ao banco de dados bruto é restrito aos administradores do sistema. O dashboard interativo consome apenas views agregadas e resultados estatísticos do modelo preditivo, garantindo que o usuário final não tenha acesso à base granular.
- **Procedimentos de Retenção:** Os dados temporários gerados durante o processamento do modelo são descartados automaticamente após a execução do pipeline.

4. Adequação à LGPD

A conformidade do projeto SUSi com a LGPD foi estruturada em torno dos princípios legais da lei:

- **Finalidade:** Os dados são utilizados exclusivamente para a análise de absenteísmo e otimização da regulação do SUS, propósito legítimo, específico e explícito.
- **Necessidade:** O pipeline de ETL coleta e processa apenas os atributos estritamente essenciais para a modelagem estatística (ex: tempo de espera, distância, especialidade), descartando qualquer informação irrelevante para a predição.
- **Transparência:** O projeto documenta publicamente sua metodologia, fontes de dados (DATASUS, SISREG) e os tratamentos realizados, garantindo rastreabilidade do processo analítico.
- **Segurança:** Implementação de arquitetura baseada em dados agregados e desidentificados, limitando a superfície de ataque.
- **Direitos do Titular:** Como o projeto utiliza bases de dados secundárias e anonimizadas fornecidas pelo poder público, a identificação individual é impossível por design (Privacy by Design), o que isenta o sistema da gestão de consentimento individual, enquadrando-se na base legal de estudos por órgão de pesquisa ou execução de políticas públicas.

5. Conclusão e Recomendações

O projeto SUSi apresenta um alto nível de maturidade em relação à privacidade e segurança. A adoção do princípio de *Privacy by Design* desde a etapa de ETL garante que o modelo analítico gere valor sem comprometer a privacidade dos cidadãos.

Pontos Fortes: A separação clara entre a base de dados granular (restrita) e o dashboard de visualização (agregado) demonstra aderência robusta ao princípio da necessidade e da segurança. A anonimização efetiva inviabiliza vazamentos críticos de dados sensíveis.

Recomendações para Evolução Contínua:

- **Auditoria de Acessos (Logs):** Implementar um sistema de logs rigoroso para registrar quem acessa a infraestrutura de dados e quando.
- **Criptografia em Repouso:** Assegurar que os volumes de armazenamento da base de dados processada utilizem criptografia forte em repouso.
- **Avaliação Periódica de Risco:** Realizar testes regulares de reidentificação utilizando técnicas estatísticas para garantir que os dados agregados continuem seguros frente a novas bases públicas que possam ser cruzadas.